Application Security Assessment and Evidence Report

Mentify Learning Management System

OWASP Top 10:2025 Risk Alignment

Informed by OWASP ASVS 5.0.0 and WSTG

Contents

Executive Summary **1**

Document Control and Assessment Basis **2**

Methodology and Evidence Classification **3**

Principal Findings Register **4**

1 Assessment Context and Interpretation **5**

1.1 Reference Framework 5

1.2 Assessment Objectives 5

1.3 Control Assessment Status 5

1.4 Evidence levels used in the tables 5

2 Scope and Evidence Limitations **7**

3 Terminology **8**

4 System Overview and Assets **10**

5 Control Assessment Summary **11**

6 Detailed OWASP Top 10 Control Assessment **14**

6.1 A01:2025 — Broken Access Control 14

6.2 A02:2025 — Security Misconfiguration 17

6.3 A03:2025 — Software Supply Chain Failures 20

6.4 A04:2025 — Cryptographic Failures 22

6.5 A05:2025 — Injection 24

6.6 A06:2025 — Insecure Design 26

6.7 A07:2025 — Authentication Failures 28

6.8 A08:2025 — Software or Data Integrity Failures 30

6.9 A09:2025 — Security Logging & Alerting Failures 32

6.10 A10:2025 — Mishandling of Exceptional Conditions 34

7 Supplementary API and AI Risk Mapping **37**

7.1 OWASP API Security Top 10:2023 37
7.2 OWASP Top 10 for LLM Applications:2025 (AI service) 37

8 Remediation Roadmap **39**

9 Recommended Verification Procedures **43**

10 Evidence register **44**

11 Review, Acceptance and Sign-off **49**

References and Reporting Conventions **52**

List of Tables

1 Assessment document control 2

2 Principal findings and required closure evidence 4

1.1 Assessment status definitions 5

2.1 Area What was read 7

3.1 Word What it means 8

4.1 Layer What it is 10

5.1 Assessment evidence table 8 12

6.1 Assessment evidence table 12 15

6.2 Assessment evidence table 16 18

6.3 Assessment evidence table 20 21

6.4 Assessment evidence table 24 23

6.5 Assessment evidence table 28 25

6.6 Assessment evidence table 32 27

6.7 Assessment evidence table 36 29

6.8 Assessment evidence table 40 31

6.9 Assessment evidence table 44 33

6.10 Assessment evidence table 48 35

7.1 Risk Plain meaning 37

7.2 Risk Plain meaning 38

8.1 Assessment evidence table 51 40

9.1 Goal Beginner-friendly way 43

10.1 Assessment evidence table 53 45

11.1 Assessment evidence table 54 50

11.2 Version Date 51

Executive Summary

This report evaluates the documented security design and available repository evidence for the Mentify Learning Management System against the OWASP Top 10:2025 risk categories. The source assessment identified 73 checks: 28 MET, 14 PARTIAL, 17 GAP and 14 CHECK. These are evidence-review labels, not verified security outcomes. The source report's 48% indicator is an internal arithmetic measure and must not be represented as a compliance rating.

Overall assessment: The documentation indicates useful design controls in authentication, authorization, input validation and application-level safeguards. Significant unresolved or unverified areas include external HTTPS termination, response security headers, initial-password delivery, security monitoring, dependency and container scanning, and internal messaging protections. The report identifies the relevant source-file observations but does not demonstrate that the production application is secure.

Assurance limitation: No live-system testing, penetration testing, vulnerability scan results or independent verification evidence were provided. Several observations originate from earlier analysis rather than re-inspection of source files. Directly reviewed backend files were on the main branch, while the integration branch is development. Accordingly, this document is a *limited-scope security evidence review*, not an OWASP certification or attestation of compliance.

Management decision required: Assign owners and deadlines to the remediation roadmap; confirm the actual deployment architecture and branch revision; execute and retain security test results; and commission a follow-up verification before any claim of operational security assurance.

Document Control and Assessment Basis

Table 1: Assessment document control

Field	Value
Document owner	Project team
Version	1.0
Client / system	Mentify Learning Management System / TIT Education
Evidence sources	SENG-34213/Mentify-backend; SENG-34213/frontend; SENG-34213/tests
Verification baseline	OWASP Top 10:2025 categories

Methodology and Evidence Classification

Method: Review available repository documentation, configuration and prior analysis; map observations to OWASP risk categories; record findings and unknowns; recommend targeted verification and remediation. This is a static, documentary assessment. No new runtime tests are claimed.

Evidence classes: E1–E5 represent named files reportedly read on the backend main branch; E6–E8 reflect earlier project review and therefore require revalidation. File names alone do not establish version-specific traceability: commit hashes, review timestamps, retained outputs and test artifacts should be added before formal acceptance.

Status interpretation: MET means a protective measure is documented or visible in the available source; PARTIAL means incomplete or insufficiently supported; GAP means a control is absent in the reviewed material or a weakness was observed; CHECK means evidence was insufficient. These statuses do not equal vulnerability severity. Findings priorities are provisional and must be confirmed against actual exposure and business impact.

Verification requirements: For formal ASVS-style assurance, define the assessment level and applicable requirement IDs, test each in-scope requirement, document exceptions and not-applicable decisions, and retain reproducible evidence. The present source does not contain that completed verification matrix.

Principal Findings Register

Table 2: Principal findings and required closure evidence

ID	Observation	Priority*	Closure / verification requirement
F-01	HTTPS not demonstrated in reviewed proxy configuration	Urgent	Verify deployed TLS and HTTP-to-HTTPS redirect; retain configuration and external TLS test results.
F-02	Security headers not defined in reviewed Caddyfile	High	Implement appropriate headers and retain response-header tests for all portals.
F-03	Initial passwords reportedly emailed in plaintext	High	Replace with expiring single-use account activation; test token expiry and replay handling.
F-04	No executed dependency, image or secret scan evidence	High	Run version-pinned scans on defined commits; retain results and remediation disposition.
F-05	Centralized security logging and alerting not evidenced	High	Document log coverage, alert routing and incident response; test alert generation.
F-06	Kafka plaintext and internal service protections incomplete	Medium	Review network trust boundary, broker authentication and TLS; document accepted residual risk.
F-07	Student AI UI inconsistent with backend authorization	Medium	Align UI with approved access policy; verify server-side enforcement and negative role tests.
F-08	No executed access-control and security test reports supplied	High	Execute authenticated negative tests and retain reproducible test artifacts.
F-09	Source and integration branch evidence mismatch	High	Reassess development/release commit and record exact repository revision for each finding.

** Priorities are proposed triage levels based on the documented observations, not confirmed CVSS scores or verified production exploitability. Finding owners, due dates, disposition and retest results remain to be assigned.*

1. Assessment Context and Interpretation

1.1 Reference Framework

OWASP (the Open Worldwide Application Security Project) is a non-profit community that publishes free security guidance. Its best-known publication is the OWASP Top 10, a list of the ten most common and serious kinds of web application security risk. The 2025 edition is the current one. Many universities, clients and auditors ask projects to show how they handle these ten risks.

1.2 Assessment Objectives

• It goes through each of the ten OWASP categories and explains it in everyday language.

• For each category it lists specific checks, what Mentify shows for that check, where the proof comes from, and a status.

• It collects the gaps into a priority action plan and explains how you can gather your own evidence.

1.3 Control Assessment Status

Table 1.1: Assessment status definitions

Status	**Meaning**	**What to do**
MET	Evidence was found that the protection exists.	Keep it; add a test so it stays true.
PARTIAL	Some protection exists but it is incomplete or unproven.	Finish it and prove it with a test.
GAP	The protection was not found, or the evidence shows a weakness.	Plan a fix (see the action plan).
CHECK	There was not enough visible evidence to say yes or no.	Look at the named place and decide.

Important: “MET” means “the design or configuration shows it”, not “we have proven it works”. A configuration file can say one thing while the running system does another. That is why the action plan keeps asking for tests.

1.4 Evidence levels used in the tables

• Named file (for example docker-compose.prod.yml): the file was opened and read during this review.

• Earlier analysis / earlier controller review: facts about controllers, services and screens gathered in the earlier repository analysis for this project, not re-read file by file in this review.

- Not found / Not read: nothing was seen, so the item is a gap or a check, not a pass.

2. Scope and Evidence Limitations

You asked for the whole repository to be read and for nothing in the repositories to be changed. Nothing was changed. The review was limited by what could be opened from outside the repositories, so please read this section before relying on the results.

Table 2.1: Area What was read

Area	What was read	Limits
Backend (Mentify-backend)	Repository front page and README; Caddyfile; docker-compose.prod.yml; .env.prod.example; docs/AUTHENTICATION_SESSION_FLOW.md; plus the earlier repository analysis of controllers, DTOs, services and migrations.	Directory listings were blocked, so individual Java files, pom.xml, workflows and migrations were not re-read here. The files opened were from the default branch (main), while your integration branch is development, so they may differ.
Frontend	Repository front page and README (earlier in this project), plus the earlier analysis of the admin, teacher, student and website applications.	Source files such as next.config, token storage code and component code were not opened. Items about browser behaviour are marked CHECK.
Tests	Repository README and its list of documents (security, resilience, performance, contract, staging).	The individual test files and their results were not read. No executed test results are recorded.
Running system	Nothing.	No scan, penetration test or live check was run. Behaviour claims are from configuration and documents.

3. Terminology

Table 3.1: Word What it means

Word	What it means
API	The set of web addresses a program can call to ask the server for something.
API Gateway	The front door of the backend. Every request goes through it first.
Authentication	Proving who you are (logging in).
Authorisation / access control	Deciding what a logged-in person may do.
RBAC (role-based access control)	Giving permissions to roles (Student, Teacher, Admin, Super Admin) instead of to individual people.
JWT (JSON Web Token)	A signed digital pass the server gives you after login. You show it with every request.
JWKS	A public list of keys that lets any service check a JWT's signature.
Refresh token	A longer-lived pass used only to get a new short-lived JWT.
OTP	One-time password, a code that works once.
MFA	Multi-factor authentication: a second proof such as a phone code.
HTTPS / TLS	The lock on a website connection that stops others from reading or changing traffic.
HSTS	A header that tells browsers to always use HTTPS for your site.
CSP	Content Security Policy, a header that limits what scripts a page may run.
CORS	Rules about which websites may call your API from a browser.
XSS	Cross-site scripting: an attacker makes your page run their script.
SQL injection	Tricking a database into running a command hidden in user input.
SSRF	Tricking a server into fetching an address chosen by an attacker.
SBOM	Software bill of materials: a list of every library inside your application.
Docker / container	A packaged mini-computer that runs one part of the system.
Kafka	A message system services use to pass events to each other.

Word	What it means
Webhook	A message another system (such as Stripe) sends to you when something happens.
Idempotent	Safe to repeat: handling the same message twice gives the same result.
Audit log	A record of who did what and when.

4. System Overview and Assets

Mentify is a web-based learning management system for TIT Education. Students, teachers and administrators sign in through separate web portals. A public website serves visitors. Behind them sits a backend of about fifteen small services working together.

Table 4.1: Layer What it is

Layer	What it is	Security relevance
Browser portals	Admin, Teacher and Student apps and a public website (Next.js / React).	What users see; menus here are convenience, never security.
Edge	Caddy reverse proxy (port 80) then Spring Cloud API Gateway.	First place where traffic is checked; where HTTPS and headers belong.
Auth service	Issues JWT access and refresh tokens, handles password recovery.	The most sensitive service.
Business services	User, course, enrollment, assignment, attendance, exam, material, payment, communication, notification, calendar, analytics, AI.	Hold the real data; each repeats the token and role checks.
Data and messaging	PostgreSQL, Redis, Kafka, S3-compatible storage.	Private network only; hold all student and payment data.
Outside providers	Stripe (payments), AI provider, SMTP email.	Third parties that receive or send data.

Assets worth protecting

- Student and teacher personal details, grades, attendance and exam results.
- Login credentials, tokens and signing keys.
- Payment records and provider keys.
- Uploaded learning material and student submissions.
- AI conversations (they may contain personal information).
- The reputation of TIT Education if data is leaked or the site is defaced.

5. Control Assessment Summary

Interpretation notice. The original 48% evidence indicator is a custom arithmetic summary, not an OWASP, ASVS, or independently verified compliance score. MET denotes a documented or configuration-level observation only; it does not establish operational effectiveness. No compliance certificate or production assurance conclusion is issued by this report.

Table 5.1: Assessment evidence table 8

OWASP Top 10:2025 category	Checks	Met	Partial	Gap	Check	Evidence score	Overall	
A01 Broken Access Control	8	3	3	1	1	56%	PARTIAL	
A02 Security Misconfiguration	10	3	0	5	2	30%	GAP	
A03 Software Supply Chain Failures	6	0	2	1	3	17%	PARTIAL	
A04 Cryptographic Failures	8	2	1	2	3	31%	PARTIAL	
A05 Injection	7	4	1	0	2	64%	PARTIAL	
A06 Insecure Design	6	4	0	2	0	67%	PARTIAL	
A07 Authentication Failures	9	5	1	2	1	61%	PARTIAL	
A08 Software or Data Integrity Failures	7	3	2	1	1	57%	PARTIAL	
A09 Security Logging & Alerting Failures	6	0	2	3	1	17%	GAP	
A10 Mishandling of Exceptional Conditions	6	4	2	0	0	83%	MET	
TOTAL	73	28	14	17	14	48%		

How the evidence score works: each MET counts as 1, each PARTIAL as one half, and GAP and CHECK as 0, divided by the number of checks. It is a simple guide to where evidence is strongest, not an official OWASP score. The Overall column is MET only when there are no gaps and few unknowns.

What the scorecard tells us

• Strongest areas: handling of errors and failures (A10, 83%), design guardrails around payments, enrolment and AI use (A06, 67%), injection controls (A05, 64%) and authentication design (A07, 61%).

• Weakest areas: supply-chain evidence (A03, 17%), logging and alerting (A09, 17%), configuration at the edge (A02, 30%) and transport encryption (A04, 31%).

• Biggest unknown: no executed security test results are recorded, so most MET items are unproven in practice.

The five findings that matter most

• No HTTPS evidence: the proxy listens on port 80 only and the issuer address is http. Passwords and tokens would travel unprotected.

• No security headers (HSTS, CSP and others) in the proxy configuration.

• New users are emailed their initial password in clear text.

• No logging collection or alerting, and no dependency or image vulnerability scanning was found.

• Kafka, the registry and the config server rely only on the private network; and the student AI screen conflicts with backend rules.

6. Detailed OWASP Top 10 Control Assessment

Each category has the same layout: what it means in plain language, why it matters for Mentify, a checklist table, then the fixes that matter most. The last column is advice only; no repository was changed.

6.1 A01:2025 — Broken Access Control

Also known as: 2021: A01 Broken Access Control (now also includes Server-Side Request Forgery)

Table 6.1: Assessment evidence table 12

What we check	What Mentify shows	Source	Status	Suggested action
Only logged-in users reach protected APIs	The API Gateway validates the JWT signature on every protected request, and each business service validates it again (shared SecurityConfig in common-lib).	Backend README (Security section)	MET	Keep both layers. Record a test that calls a service directly without a token and expects 401.
Role checks on each operation	Methods use Spring Security role checks such as @PreAuthorize(”hasRole(‘TEACHER’)”). Roles are fixed: STUDENT, TEACHER, ADMIN, SUPER_ADMIN. Deleting a course is limited to Admin and Super Admin; AI chat is limited to Teacher, Admin and Super Admin.	Backend README; earlier controller review	MET	Generate a full endpoint-by-role table from the controller annotations and keep it with the tests.
Users only reach their own records (object-level checks)	Specialised authorisation services exist (for example MaterialAuthorizationServiceImpl) and teachers are limited to assigned courses; students see only their own payments.	Backend README; earlier service review	PARTIAL	Prove it with tests: log in as Student A and request Student B’s submission, grade, payment and file. Every one must fail.
Hidden or public routes are intentional	Refresh, logout and forgot-password are deliberately reachable without an access token, and auth-service stays the authority for them.	AUTHENTICATION_SESSION_FLOW.md	MET	Keep a short list of all public routes and review it whenever a route is added.
Frontend menus match backend permissions	The student app contains an AI client that calls /api/ai/chat, but the backend allows only Teacher, Admin and Super Admin. The backend is correct to refuse it; the screen and the rule disagree.	Earlier frontend and backend review	GAP	Remove or hide the student AI chat screen, or decide to allow students and add the role with tests. Never rely on hiding a menu for security.
Cross-origin access (CORS) is restricted	Allowed origins are set through GATEWAY_CORS_ALLOWED_ORIGIN_PATTERNS rather than hard-coded.	.env.prod.example	PARTIAL	Set it to the exact portal addresses. Do not use * in production.
Server-Side Request Forgery (SSRF) is considered	No feature that fetches a user-supplied web address was identified. Services call each other by fixed internal names. File extraction runs on uploaded files, not on links.	Earlier repository review	CHECK	Search the code for HTTP clients that accept a URL from a request and confirm none exist.

What we check	What Mentify shows	Source	Status	Suggested action
Access tests exist and have been run	The tests repository covers authentication and authorisation, but live suites are opt-in and no executed results are recorded in this review.	tests README	PARTIAL	Run the integration profile against a test environment and save the report as evidence.

Result for A01: 3 met, 3 partial, 1 gap, 1 to check.

Recommended actions for A01

• Users only reach their own records (object-level checks): Prove it with tests: log in as Student A and request Student B's submission, grade, payment and file. Every one must fail.

• Frontend menus match backend permissions: Remove or hide the student AI chat screen, or decide to allow students and add the role with tests. Never rely on hiding a menu for security.

• Cross-origin access (CORS) is restricted: Set it to the exact portal addresses. Do not use * in production.

• Access tests exist and have been run: Run the integration profile against a test environment and save the report as evidence.

6.2 A02:2025 — Security Misconfiguration

Also known as: 2021: A05 Security Misconfiguration (moved up to #2 in 2025)

Table 6.2: Assessment evidence table 16

What we check	What Mentify shows	Source	Status	Suggested action
Secrets are not in the code	The production Compose file refuses to start unless key secrets are supplied (the :? checks for database, Redis and JWT settings). A .env.prod file is used on the server and only .env.example and .env.prod.example are in the repository.	docker-compose.prod.yml; .env.prod.example	MET	Run a secret scanner (such as gitleaks) over the full Git history, not only the latest files.
Databases and brokers are not exposed to the internet	PostgreSQL, Redis and Kafka have no published ports; they sit on the private Docker network. The API gateway is published only on 127.0.0.1:8080 and only Caddy publishes port 80.	docker-compose.prod.yml	MET	Confirm the cloud firewall (security group) allows only the ports you intend.
Production settings are safe	Hibernate is set to validate (it cannot rewrite the database), SQL logging is off, sample users and super-admin bootstrap are off by default, and ephemeral signing keys are off.	.env.prod.example	MET	Confirm the live .env.prod matches the template.
Security headers are sent to browsers	The Caddyfile only compresses responses, limits uploads to 110 MB and routes paths. No HSTS, Content-Security-Policy, X-Content-Type-Options, X-Frame-Options or Referrer-Policy header is set there.	Caddyfile	GAP	Add the standard security headers in Caddy or in the Next.js configuration, then check with curl -I.
Internal tools are protected	Eureka (service registry) and the Config Server run on the private network, but the Compose file shows no authentication for them.	docker-compose.prod.yml	CHECK	Confirm they are unreachable from outside, and consider adding authentication.
Management (actuator) endpoints are limited	Health endpoints are used for health checks. Whether other actuator endpoints (env, beans, heapdump) are disabled in production was not visible.	Backend README	CHECK	Confirm that only health information is exposed in the prod profile.
Kafka is configured safely	Kafka uses PLAINTEXT listeners with no login, topics are created automatically, and there is one broker with replication factor 1.	docker-compose.prod.yml	GAP	Acceptable only on a closed private network. Plan SASL/TLS and fixed topics before growth.

What we check	What Mentify shows	Source	Status	Suggested action
Containers are hardened	Restart policy and health checks exist for several services. No non-root user, read-only filesystem, dropped capabilities or resource limits are shown.	docker-compose.prod.yml	GAP	Add non-root users, memory/CPU limits and read-only filesystems where possible.
Repository hygiene	The repository root contains a committed log file (maven-attendance.log) and a macOS .DS_Store file. Postman and .ai/mcp folders are also committed.	Backend repository root listing	GAP	Remove logs and system files from Git and check Postman collections for tokens or passwords.
Documentation matches reality	The backend README still describes six services, MongoDB and AWS RDS; the frontend README claims WCAG 2.1 AA and AWS CloudFront.	Both READMEs	GAP	Update the READMEs so reviewers and operators are not misled.

Result for A02: 3 met, 0 partial, 5 gap, 2 to check.

Recommended actions for A02

• Security headers are sent to browsers: Add the standard security headers in Caddy or in the Next.js configuration, then check with curl -I.

• Kafka is configured safely: Acceptable only on a closed private network. Plan SASL/TLS and fixed topics before growth.

• Containers are hardened: Add non-root users, memory/CPU limits and read-only filesystems where possible.

• Repository hygiene: Remove logs and system files from Git and check Postman collections for tokens or passwords.

6.3 A03:2025 — Software Supply Chain Failures

Also known as: 2021: A06 Vulnerable and Outdated Components (broadened in 2025)

Table 6.3: Assessment evidence table 20

What we check	What Mentify shows	Source	Status	Suggested action
Dependency versions are locked	The frontend has a package-lock.json. Maven versions are managed in the pom files.	Frontend repository listing	PARTIAL	Keep lock files committed and install with npm ci in CI.
Known vulnerabilities are scanned	No dependency scanning (OWASP Dependency-Check, npm audit, Dependabot, Trivy) was seen in the files reviewed. The GitHub Security tab exists but its findings were not visible.	Repository navigation; no scan config seen	CHECK	Turn on Dependabot alerts and run npm audit, Dependency-Check and an image scan; save the reports.
Framework and database versions are supported	The repository analysis reported Spring Boot 3.2.5. The 3.2 line left open-source support in late 2024. PostgreSQL 14 reaches its end of life in November 2026. Both are worth confirming.	Earlier analysis; docker-compose.prod.yml	CHECK	Read the exact versions in pom.xml, compare with the vendors' support pages and plan upgrades.
Container images are pinned	postgres:14-alpine, redis:7.4-alpine and apache/kafka:3.9.1 are pinned to a version; caddy:2-alpine floats within major 2; the application image defaults to the tag latest.	docker-compose.prod.yml	PARTIAL	Use exact version tags or digests for every image and a fixed IMAGE_TAG for releases.
Build pipeline is trusted	GitHub Actions workflows exist in all three repositories. Whether third-party actions are pinned to a commit, or builds are signed, was not visible.	Repository listings	CHECK	Pin actions to commit SHAs and restrict workflow permissions.
A software bill of materials (SBOM) exists	No SBOM generation was seen.	Not found	GAP	Generate a CycloneDX SBOM in CI for backend and frontend.

Result for A03: 0 met, 2 partial, 1 gap, 3 to check.

Recommended actions for A03

• Dependency versions are locked: Keep lock files committed and install with npm ci in CI.

• Container images are pinned: Use exact version tags or digests for every image and a fixed IMAGE_TAG for releases.

• A software bill of materials (SBOM) exists: Generate a CycloneDX SBOM in CI for backend and frontend.

6.4 A04:2025 — Cryptographic Failures

Also known as: 2021: A02 Cryptographic Failures (now #4)

Table 6.4: Assessment evidence table 24

What we check	What Mentify shows	Source	Status	Suggested action
Login tokens are signed with a key pair	Tokens are signed with a private key; services verify with the public key published as JWKS. The key pair comes from environment settings, with a key id and audience, and temporary keys are switched off.	.env.prod.example	MET	Document who holds the private key and how it is rotated.
Traffic from browsers is encrypted (HTTPS)	The Caddyfile listens on HTTP port 80 only, and the template issuer address starts with http://. The README diagram shows HTTPS, but no TLS setup is present in the files reviewed.	Caddyfile; .env.prod.example	GAP	Serve the site on a real domain name so Caddy obtains certificates, redirect HTTP to HTTPS and set the issuer to https.
Passwords are stored as strong hashes	The design says passwords are hashed with BCrypt. The exact cost factor was not verified.	Earlier design documents	CHECK	Open the auth-service password configuration and confirm BCrypt cost of 12 or more (or Argon2).
Passwords are never sent in clear text	New accounts receive an email containing the generated initial password.	AUTHENTICATION_SESSION_FLOW.md	GAP	Send a one-time set-password link instead, and expire it quickly.
File links are time-limited	Download URLs are presigned and expire after 900 seconds. The server uses an IAM role, not stored keys.	.env.prod.example	MET	Keep expiry short and log downloads.
Other connections are encrypted	Email uses STARTTLS. Stripe and AI providers are reached over HTTPS by their nature. Internal traffic (PostgreSQL, Redis, Kafka, service to service) is plain text inside the private network.	.env.prod.example; docker-compose.prod.yml	PARTIAL	Accept internal plain text only on a closed network and document the decision.
Data at rest is encrypted	Nothing in the files shows disk or volume encryption for the database, Kafka or uploaded files.	Not found	CHECK	Enable encrypted volumes on the server and server-side encryption on the storage bucket.
Where the browser keeps tokens	How the portals store tokens (memory, cookie or local storage) was not visible.	Not read	CHECK	Prefer short-lived tokens in memory or HttpOnly cookies and avoid local storage.

Result for A04: 2 met, 1 partial, 2 gap, 3 to check.

Recommended actions for A04

• Traffic from browsers is encrypted (HTTPS): Serve the site on a real domain name so Caddy obtains certificates, redirect HTTP to HTTPS and set the issuer to https.

• Passwords are never sent in clear text: Send a one-time set-password link instead, and expire it quickly.

• Other connections are encrypted: Accept internal plain text only on a closed network and document the decision.

6.5 A05:2025 — Injection

Also known as: 2021: A03 Injection (includes cross-site scripting)

Table 6.5: Assessment evidence table 28

What we check	What Mentify shows	Source	Status	Suggested action
Database queries are parameterised	Services use Spring Data JPA/Hibernate, which sends values separately from the query, and Flyway for fixed migrations.	Backend README	PARTIAL	Search for native queries and string concatenation with grep and review each one.
Input is validated	Request objects carry rules such as title length of 150, marks of at least 1, late penalty 0 to 100 and a maximum of 100 quiz questions.	Earlier DTO review	MET	Check that every request object has constraints and that controllers use @Valid.
Browser output is escaped (XSS)	React and Next.js escape text by default. Use of dangerouslySetInnerHTML or rendering of AI or message text as HTML was not reviewed.	Framework behaviour	CHECK	Search the frontend for dangerouslySetInnerHTML and for markdown renderers, and sanitise anything shown as HTML.
Uploaded files are checked	The material service validates file type and size. The public website download route checks the file is in the catalogue, blocks paid files, validates the name and extension and blocks path traversal.	Earlier analysis	MET	Add a malware scan for uploads if students can upload files.
Request size is limited	Caddy rejects bodies over 110 MB.	Caddyfile	MET	Check that the gateway and each service also enforce their own limits.
AI prompt injection is addressed	Prompt-injection detection and content filtering are switched on, with rate and daily limits.	.env.prod.example	MET	Keep adversarial test prompts in the test suite.
Email and header injection	Email is sent through SMTP templates; whether user text can reach headers was not reviewed.	Not read	CHECK	Confirm that names and subjects are never placed in email headers unescaped.

Result for A05: 4 met, 1 partial, 0 gap, 2 to check.

Recommended actions for A05

• Database queries are parameterised: Search for native queries and string concatenation with grep and review each one.

6.6 A06:2025 — Insecure Design

Also known as: 2021: A04 Insecure Design (now #6)

Table 6.6: Assessment evidence table 32

What we check	What Mentify shows	Source	Status	Suggested action
Defence in depth	Security is enforced at the gateway, in every service and on resource ownership, and each service has its own database user in the template.	Backend README; .env.prod.example	MET	Keep it this way as services are added.
Sensitive business flows have guardrails	Self-enrolment starts as PENDING and needs approval, and paid courses need a verified payment. Quizzes have attempt limits and windows, and assignments have late-submission rules (HTTP 409).	Earlier analysis	MET	Add abuse tests (replayed webhook, duplicate enrolment, exceeding attempts).
AI usage is controlled	Quotas of 60 requests a minute and 1,000 a day, role limits, and teacher review of generated quizzes before they are published.	.env.prod.example; earlier analysis	MET	Review the limits against provider cost.
Login abuse is limited	Accounts lock after 5 failed attempts for 15 minutes.	.env.prod.example	MET	Add rate limiting on login and forgot-password at the gateway as well.
A written threat model exists	No threat model or abuse-case document was found.	Not found	GAP	Write a one-page threat model for each portal using the STRIDE questions.
Design and implementation agree	The student AI screen exists but the backend forbids it; emailing initial passwords conflicts with the stated password goals.	Earlier analysis; auth flow doc	GAP	Resolve these two design conflicts and record the decision.

Result for A06: 4 met, 0 partial, 2 gap, 0 to check.

Recommended actions for A06

- A written threat model exists: Write a one-page threat model for each portal using the STRIDE questions.
- Design and implementation agree: Resolve these two design conflicts and record the decision.

6.7 A07:2025 — Authentication Failures

Also known as: 2021: A07 Identification and Authentication Failures

Table 6.7: Assessment evidence table 36

What we check	What Mentify shows	Source	Status	Suggested action
Credentials are checked by a single authority	auth-service verifies the email and password and issues signed access and refresh tokens.	AUTHENTICATION_SESSION_FLOW.md	MET	Keep all credential logic inside auth-service.
Brute force is slowed down	Account lockout after 5 failed attempts for 15 minutes.	.env.prod.example	MET	Also add IP-based rate limiting.
Account existence is not revealed	Forgot-password always returns the same message whether or not the email exists, and errors do not expose provider details or stack traces.	AUTHENTICATION_SESSION_FLOW.md	MET	Check login error messages and timing are also uniform.
Sessions are time-limited and can be ended	The template sets access tokens to 900 seconds and refresh tokens to 30 days. Logout invalidates the stored refresh session. The auth doc shows 86400 seconds for both, so the documents disagree.	.env.prod.example; AUTHENTICATION_SESSION_FLOW.md	PARTIAL	Decide the real values, make the docs match and consider rotating refresh tokens on every use.
Passwords are reset safely	Reset uses a one-time password flow handled by auth-service. First login forces a password change.	AUTHENTICATION_SESSION_FLOW.md	MET	Confirm OTP lifetime, single use and attempt limits in the code.
Initial passwords are delivered safely	The generated initial password is emailed to the new user.	AUTHENTICATION_SESSION_FLOW.md	GAP	Use a set-password link that expires.
Password rules exist	Minimum length and complexity or breached-password checks were not visible.	Not found	CHECK	Require at least 12 characters (NIST SP 800-63B) and block common passwords.
Strong sign-in for powerful roles	Multi-factor authentication is not implemented (deferred in the requirements).	Requirements review	GAP	Add MFA at least for Admin and Super Admin.
Default accounts are off	Sample users and super-admin bootstrap are false by default in the production template.	.env.prod.example	MET	Verify the live server values.

Result for A07: 5 met, 1 partial, 2 gap, 1 to check.

Recommended actions for A07

• Sessions are time-limited and can be ended: Decide the real values, make the docs match and consider rotating refresh tokens on every use.

• Initial passwords are delivered safely: Use a set-password link that expires.

• Strong sign-in for powerful roles: Add MFA at least for Admin and Super Admin.

6.8 A08:2025 — Software or Data Integrity Failures

Also known as: 2021: A08 Software and Data Integrity Failures

Table 6.8: Assessment evidence table 40

What we check	What Mentify shows	Source	Status	Suggested action
Payment events are authentic	Stripe webhooks are checked with a webhook secret, and processed event identifiers are stored so duplicates are ignored.	.env.prod.example; earlier analysis	MET	Add a test that a forged or replayed event changes nothing.
Tokens cannot be forged	JWTs are signed and the audience and issuer are configured; services verify against JWKS.	.env.prod.example	MET	Confirm services reject tokens with the wrong audience.
Database changes are controlled	Flyway keeps versioned migrations and Hibernate only validates the schema.	.env.prod.example	MET	Review migrations in pull requests.
Internal events are trustworthy	Kafka has no authentication and uses plain text; events are published by an aspect in common-lib and consumed by the notification-service.	docker-compose.prod.yml; Backend README	PARTIAL	Restrict who can publish, validate event structure on receipt and avoid sensitive data in events.
Release images are what was built	The application image tag defaults to latest. No image signing or provenance was seen.	docker-compose.prod.yml	GAP	Release by fixed tag or digest and sign images.
CI/CD is protected	Branch protection and required reviews are described in the test repository (pull requests need review and passing CI). Workflow permissions were not visible.	tests README	PARTIAL	Limit workflow permissions and require approvals for deployment.
Uploaded content integrity	Files are stored in object storage with metadata and audit events. Checksums or malware scanning were not seen.	Earlier analysis	CHECK	Store a hash for each upload and scan files if possible.

Result for A08: 3 met, 2 partial, 1 gap, 1 to check.

Recommended actions for A08

• Internal events are trustworthy: Restrict who can publish, validate event structure on receipt and avoid sensitive data in events.

• Release images are what was built: Release by fixed tag or digest and sign images.

• CI/CD is protected: Limit workflow permissions and require approvals for deployment.

6.9 A09:2025 — Security Logging & Alerting Failures

Also known as: 2021: A09 Security Logging and Monitoring Failures

Table 6.9: Assessment evidence table 44

What we check	What Mentify shows	Source	Status	Suggested action
Important actions leave audit records	AI requests create audit events; materials have an audit trail; the admin portal has an Audit and Activity area.	Earlier analysis; admin sidebar	PARTIAL	List every security event (login, failed login, role change, payment, refund, delete) and confirm each is recorded.
Secrets are kept out of logs	The documentation states that tokens, passwords and client secrets must not be logged and that errors must be controlled.	AUTHENTICATION_SESSION_FLOW.md	PARTIAL	Verify in code and by reading real log output after a login test.
Logs are collected centrally	No log aggregation, retention rule or search tool was seen. Containers log to their own output.	docker-compose.prod.yml	GAP	Ship logs to a central place (for example Loki or CloudWatch) with retention.
Alerts exist	No alerting on repeated failed logins, lockouts, 5xx errors or webhook failures was seen. Health checks exist but are not alerts.	Not found	GAP	Set up alerts for the top five security events.
Logs are protected	Whether logs are protected from change and deletion was not visible.	Not found	CHECK	Store logs where application accounts cannot alter them.
No logs in the repository	A Maven log (maven-attendance.log) is committed at the backend repository root.	Backend repository root listing	GAP	Remove it and keep *.log in .gitignore.

Result for A09: 0 met, 2 partial, 3 gap, 1 to check.

Recommended actions for A09

• Important actions leave audit records: List every security event (login, failed login, role change, payment, refund, delete) and confirm each is recorded.

• Secrets are kept out of logs: Verify in code and by reading real log output after a login test.

• Logs are collected centrally: Ship logs to a central place (for example Loki or CloudWatch) with retention.

• Alerts exist: Set up alerts for the top five security events.

6.10 A10:2025 — Mishandling of Exceptional Conditions

Also known as: New in 2025

Table 6.10: Assessment evidence table 48

What we check	What Mentify shows	Source	Status	Suggested action
Errors are controlled	Shared exception handlers return structured responses (for example a controlled 401 JSON) without stack traces or provider details. Business conflicts return HTTP 409.	Backend README; auth flow doc	MET	Test that a deliberate server error returns no stack trace.
Failures do not open the door	Invalid, expired or revoked tokens return 401. Services require JWT settings or fail to start.	docker-compose.prod.yml; auth flow doc	MET	Test the behaviour when the key service is unreachable (it must deny, not allow).
External calls have time-outs and retries	AI calls use a 5 second connect and 60 second read timeout with up to 3 retries. Email retries up to 3 times.	.env.prod.example	MET	Add a circuit breaker if provider outages become frequent.
Duplicate events are safe	Stripe events are processed only once.	Earlier analysis	MET	Keep the idempotency test.
Dependencies failing is expected	Services wait for healthy dependencies at start. Business services have no health checks of their own in the Compose file.	docker-compose.prod.yml	PARTIAL	Add health checks to every business service.
Failure behaviour is tested	The tests repository describes resilience tests, but they are opt-in and no executed results are recorded.	tests README	PARTIAL	Run and save the resilience results.

Result for A10: 4 met, 2 partial, 0 gap, 0 to check.

Recommended actions for A10

- Dependencies failing is expected: Add health checks to every business service.
- Failure behaviour is tested: Run and save the resilience results.

7. Supplementary API and AI Risk Mapping

Mentify is mostly a set of web APIs, and it has an AI service. OWASP publishes two shorter lists for these. They overlap with the Top 10, so this section only points to the evidence already given.

7.1 OWASP API Security Top 10:2023

Table 7.1: Risk Plain meaning

Risk	Plain meaning	Mentify position	Status
API1 Broken Object Level Authorization	Reaching another user's record by changing an id.	Ownership checks exist in places; needs a test per endpoint (see A01).	PARTIAL
API2 Broken Authentication	Weak login or token handling.	Signed JWT, lockout, controlled errors; MFA missing (see A07).	PARTIAL
API3 Broken Object Property Level Authorization	Seeing or changing fields you should not (for example role).	DTO-based requests limit fields; not tested.	CHECK
API4 Unrestricted Resource Consumption	No limits on size, rate or cost.	Upload size and AI quotas exist; gateway rate limiting not confirmed.	PARTIAL
API5 Broken Function Level Authorization	Using admin functions as a normal user.	Role checks on methods; student AI mismatch noted.	PARTIAL
API6 Unrestricted Access to Sensitive Business Flows	Abusing flows such as enrolment, payment or quizzes.	Pending approval, payment verification and attempt limits exist.	MET
API7 Server Side Request Forgery	Making the server fetch attacker-chosen links.	No such feature identified.	CHECK
API8 Security Misconfiguration	Unsafe settings.	See A02: headers, Kafka, HTTPS.	GAP
API9 Improper Inventory Management	Forgotten or undocumented endpoints and versions.	Postman collections and docs exist; no maintained API inventory or OpenAPI list was seen.	PARTIAL
API10 Unsafe Consumption of APIs	Trusting data from other APIs.	Stripe signatures verified; AI output reviewed by teachers for quizzes.	MET

7.2 OWASP Top 10 for LLM Applications:2025 (AI service)

Table 7.2: Risk Plain meaning

Risk	Plain meaning	Mentify position	Status
LLM01 Prompt Injection	Tricking the AI with hidden instructions.	Detection and content filtering enabled.	MET
LLM02 Sensitive Information Disclosure	The AI reveals private data.	Tools return only data the requester may see; conversations are stored per user.	PARTIAL
LLM03 Supply Chain	Unsafe models or libraries.	Provider is configurable; no vendor review recorded.	CHECK
LLM04 Data and Model Poisoning	Bad data corrupts behaviour.	Hosted model, no training by the project; uploaded source material feeds prompts.	CHECK
LLM05 Improper Output Handling	Using AI output unsafely.	Quiz drafts must be reviewed by a teacher; rendering of AI text not reviewed.	PARTIAL
LLM06 Excessive Agency	Letting the AI do too much.	Tools are read-only data lookups and role-restricted.	MET
LLM07 System Prompt Leakage	Revealing hidden instructions.	Not reviewed.	CHECK
LLM08 Vector and Embedding Weaknesses	Weak retrieval stores.	No vector store identified.	CHECK
LLM09 Misinformation	Confident wrong answers.	Grounding in platform data; no accuracy measurement.	PARTIAL
LLM10 Unbounded Consumption	Runaway cost or load.	60 requests per minute and 1,000 per day limits, timeouts and retries.	MET

8. Remediation Roadmap

This list is for when you are allowed to make changes again. Effort is a rough guide: S is a day or less, M is a few days, L is more than a week.

Table 8.1: Assessment evidence table 51

#	**Priority**	**Action**	**Fixes**	**Effort**
1	Do first	Serve the site over HTTPS on a real domain, redirect HTTP to HTTPS and change the issuer address to https.	A04, A02	S
2	Do first	Add security headers (HSTS, CSP, X-Content-Type-Options, X-Frame-Options, Referrer-Policy).	A02, A05	S
3	Do first	Stop emailing initial passwords; send an expiring set-password link.	A04, A07	M
4	Do first	Run dependency, image and secret scans (Dependency-Check, npm audit, Trivy, gitleaks) and save the reports; confirm Spring Boot and PostgreSQL versions are supported.	A03	S

#	Priority	Action	Fixes	Effort
5	Do first	Run the opt-in integration, authorisation and resilience tests and save the results as proof.	A01, A10	M
6	Next	Central logs and alerts for failed logins, lockouts, 5xx errors and webhook failures.	A09	M
7	Next	Remove maven-attendance.log and .DS_Store from Git, add them to .gitignore, and check Postman files for secrets.	A02, A09	S
8	Next	Decide the real token lifetimes and make the documents agree; consider rotating refresh tokens.	A07	S
9	Next	Fix the student AI mismatch (remove the screen or authorise the role) and write down the decision.	A01, A06	S

#	Priority	Action	Fixes	Effort
10	Next	Pin every image to an exact version or digest and release by fixed tag.	A03, A08	S
11	Next	Add MFA for Admin and Super Admin.	A07	L
12	Later	Secure Kafka (SASL/TLS, fixed topics), add authentication to the registry and config server, harden containers (non-root, limits).	A02, A08	L
13	Later	Write a short threat model for each portal and the payment flow.	A06	M
14	Later	Generate an SBOM in CI and pin GitHub Actions to commit SHAs.	A03, A08	M
15	Later	Update the README files so they describe the real system.	A02	S

9. Recommended Verification Procedures

Auditors trust results more than statements. These steps help you create proof. Run them only against your own test or staging environment, never against a system you do not own and never against production without approval.

Table 9.1: Goal Beginner-friendly way

Goal	**Beginner-friendly way**	**What to save**
Check security headers	Run: curl -I https://your-site and read which headers appear.	The command output (screenshot).
Check HTTPS	Open the site in a browser and look for the padlock; try the http:// address and confirm it redirects.	Screenshot of the padlock and the redirect.
Scan backend libraries	Run: mvn org.owasp:dependency-check-maven:check	The HTML report.
Scan frontend packages	Run: npm audit in each portal folder.	The command output.
Scan container images	Run Trivy (trivy image your-image:tag).	The report.
Find leaked secrets	Run gitleaks over the full Git history.	The report (it should be empty or explained).
Test access control	Log in as Student A and try to open Student B's records; log in as Student and call an Admin endpoint. Every attempt should fail with 403 or 404.	A table of attempt, expected and actual result.
Test login limits	Enter a wrong password six times and confirm the account locks for 15 minutes.	Screenshots and times.
Scan the running site	Run the OWASP ZAP baseline scan against staging.	The ZAP report.
Run the project tests	Use the tests repository: set TEST_ENV_ENABLED=true and run mvn verify -Pintegration.	The Surefire and Failsafe reports.

10. Evidence register

Table 10.1: Assessment evidence table 53

ID	Item	Location	What it proves	Read in this review?
E1	Backend README (security, event, AI sections)	Mentify-backend, README.md	Gateway and service JWT validation, role checks, inter-service token propagation, ownership checks, AI guards, Kafka notifications. States it is partly stale.	Yes (main branch)
E2	Caddy configuration	Mentify-backend, Caddyfile	Listens on :80, gzip, 110 MB body limit, routes /api and the three portals; no security headers.	Yes (main branch)

ID	Item	Location	What it proves	Read in this review?
E3	Production Compose file	Mentify-backend, docker-compose.prod.yml	Required secrets, private data stores, loopback gateway, health checks, image tags, Kafka plaintext.	Yes (main branch)
E4	Production environment template	Mentify-backend, .env.prod.example	Token lifetimes, lockout, JWT keys, quotas, S3 and Stripe settings, safe defaults.	Yes (main branch)
E5	Authentication flow guide	Mentify-backend, docs/AUTHENTICATION_SESSION_FLOW.md	Login, refresh, logout, forgot-password behaviour and controlled errors; initial password emailed.	Yes (main branch)

ID	Item	Location	What it proves	Read in this review?
E6	Frontend README and structure	frontend repository	Four applications, Docker production file, Playwright tests; README claims not verified.	Earlier in this project
E7	Test repository README	tests repository	Integration, security, resilience, performance and staging documents; live tests opt-in; review rules for pull requests.	Earlier in this project
E8	Controller, DTO and service analysis	Backend development branch	Role annotations, AI role limits, validation limits, payment webhook handling.	Earlier analysis

Re-check E1 to E5 on the development branch before final submission. The default branch was used where the direct files were readable.

11. Review, Acceptance and Sign-off

Complete this page when the checklist has been reviewed and the CHECK items resolved.

Table 11.1: Assessment evidence table 54

Role	Name	Date	Signature	Comments
Security lead / author				
Technical reviewer				
Academic supervisor				
Client representative				

Document history

Table 11.2: Version Date

Version	Date	Change
1.0	25 October 2026	First OWASP checklist based on a read-only repository review.

Disclaimer. This document records evidence and observations; it is not a penetration test, certification or guarantee. OWASP, the OWASP Top 10 and related lists are projects of the OWASP Foundation.

References and Reporting Conventions

1. OWASP, *OWASP Top 10:2025*, https://top10.owasp.org/2025/.
2. OWASP, *Application Security Verification Standard, Version 5.0.0*, https://asvs.owasp.org/.
3. OWASP, *Web Security Testing Guide*, https://wstg.owasp.org/.
4. OWASP ASVS, *Assessment and Certification Guidance*, https://github.com/OWASP/ASVS/blob/master/5.0/en/0x04-Assessment_and_Certification.md.

Reporting note: OWASP does not issue official certifications for this report. Any future ASVS verification claim must identify exact applicable requirements, assessment scope, methods, exceptions, evidence and responsible verifier. The original source document's descriptions have been retained where practicable and have not been independently revalidated against a live environment.